



Submitted by Arya Sharma

Date 10/05/26

FORENSIC INCIDENT REPORT

& POST-INCIDENT ANALYSIS

Phase 9 & 10 Analysis

Incident ID	INC-2024-0042
Classification	CRITICAL — Protected Health Information (PHI) Breach
Date of Incident	2024 (Simulated Exercise)
Report Date	May 11, 2026
Prepared By	Security Operations Center (SOC) — Incident Response Team
Status	CONTAINED & REMEDIATED

1. Executive Summary

On the date of the incident, a threat actor gained unauthorized access to a healthcare organization's internal network through a phishing email containing a malicious macro-enabled Word document. The attacker established persistence, moved laterally, and exfiltrated Protected Health Information (PHI) via an encrypted C2 channel on port 4444 over a dwell period of approximately 7.8 hours before detection.

CONFIRMED IMPACT:

- PHI records potentially exfiltrated from an internal file server.
- Attacker achieved lateral movement to at least one additional workstation.
- Reverse shell established using Netcat; C2 beaconing active for 7+ hours without triggering any alert.
- No encryption-at-rest bypass was detected; exfiltration occurred via outbound TCP on non-standard port.

CURRENT STATUS:

- Compromised host(s) isolated and rebuilt from clean images.
- C2 IP addresses blocked at the perimeter firewall.
- Wazuh detection rules updated for non-standard outbound TCP traffic.
- Incident formally contained; monitoring enhanced across all endpoints.

This report consolidates Phase 9 (Post-Incident Analysis) and Phase 10 (Final Forensic Report) findings, covering root cause analysis, forensic evidence, remediation actions, and forward-looking recommendations to prevent recurrence.

2. Attack Timeline

The following table reconstructs key events from initial access through containment, based on disk image artifacts, memory forensics, network PCAP analysis, and SIEM log correlation.

Time (T+)	Event	Detail
T+0:00	Initial Access	Phishing email delivered with malicious .docm attachment (macro-enabled). User opened the file.
T+0:05	Payload Execution	VBA macro executed PowerShell cradle; malicious PE downloaded and executed in memory.
T+0:12	Persistence	Registry Run key added: HKCU\Software\Microsoft\Windows\CurrentVersion\Run. Scheduled task created.
T+0:30	C2 Established	Reverse shell to external IP via Netcat on TCP port 4444. Beaconing begins — no alert triggered.
T+1:15	Credential Harvesting	Mimikatz executed in memory; NTLM hashes extracted for 3 domain accounts.

T+2:40	Lateral Movement	Pass-the-Hash attack via SMB (port 445) to internal file server FS01. WMI remote execution observed.
T+4:00	Data Staging	PHI files identified and staged in %TEMP% directory. 7-Zip used to compress and password-protect archive.
T+6:30	Exfiltration	Compressed archive exfiltrated over encrypted TCP/4444 channel. Estimated data volume: ~2.3 GB.
T+7:48	Detection	SOC analyst noticed unusual outbound traffic during manual review. Alert escalated. Incident declared.
T+9:50	Containment	Compromised hosts isolated. C2 IPs blocked at firewall. Incident Response team engaged.

3. Forensic Findings

3.1 Disk Image Analysis

- Prefetch files confirmed execution of powershell.exe, cmd.exe, and an unsigned binary (svchost32.exe) outside System32.
- MFT (\$MFT) analysis revealed creation of staging directory C:\Users\[user]\AppData\Local\Temp\exfil\ at T+4:00.
- Registry hive (NTUSER.DAT) contained persistence key pointing to the malicious binary path.
- Evidence of anti-forensic activity: Event log entries for Security and System partially wiped via wevtutil.exe.
- Volume Shadow Copies deleted using vssadmin.exe — consistent with ransomware/exfiltration tradecraft.

3.2 Memory Analysis (Volatility)

- Process tree anomaly: svchost32.exe spawned by explorer.exe (not services.exe) — clear indicator of compromise.
- Mimikatz artifacts identified in process memory of lsass.exe; NTLM credential hashes recovered.
- Injected shellcode detected in the memory space of a legitimate Windows process (process hollowing suspected).
- Network connections in memory corroborated C2 beaconing to 185.220.xx.xx on TCP/4444.

3.3 Network / PCAP Analysis

- Wireshark analysis of captured traffic confirmed sustained beaconing pattern: 60-second intervals over TCP/4444.
- TLS-encrypted payload with self-signed certificate to external IP — certificate fingerprint flagged on VirusTotal.
- DNS queries for dynamic DNS domain (*.duckdns.org) immediately preceding C2 connection — classic C2 pattern.

- SMB lateral movement: 47 authentication events to FS01 using harvested credentials within a 90-minute window.
- Exfiltration stream: ~2.3 GB outbound over encrypted C2 channel between T+6:30 and T+7:48.

3.4 Malware Analysis

- Initial payload: macro-enabled Word document (.docm) with obfuscated VBA; PowerShell cradle decoded from Base64.
- Second-stage payload: Unsigned PE binary; static analysis via strings and DIE confirmed Netcat variant compiled for Windows.
- VirusTotal: 38/72 engines flagged the binary; classified as Backdoor.NetCat and Trojan.Generic.
- MITRE ATT&CK TTPs mapped: T1566.001 (Phishing), T1059.001 (PowerShell), T1003.001 (LSASS Memory), T1021.002 (SMB/Windows Admin Shares), T1041 (Exfiltration Over C2 Channel).

4. Root Cause Analysis — 5 Whys

Methodology: The 5 Whys technique was applied starting from the confirmed security event. Each answer surfaces the next causal layer, ultimately identifying the systemic root cause.

#	Question	Answer / Finding
1	Why was patient data exfiltrated?	The attacker had undetected access to the network for more than 7 hours, enabling data staging and exfiltration.
2	Why was the attacker undetected for so long?	C2 beaconing over TCP port 4444 generated no SIEM alert — no detection rule existed for this traffic pattern.
3	Why was there no alert rule for port 4444?	Detection rules had not been reviewed or updated in over 6 months; coverage gaps accumulated silently.
4	Why were detection rules not reviewed?	No scheduled detection engineering process existed within the SOC; rule updates were ad-hoc and reactive.
5	Why is there no detection engineering process?	ROOT CAUSE: No formal SOC improvement framework is in place. Detection maturity has never been formally assessed or governed.

ROOT CAUSE SUMMARY:

The absence of a formal SOC improvement and detection engineering framework created a systemic gap in detection coverage. Without a structured review cycle, the organization's SIEM rule set became stale, leaving common adversary C2 ports unmonitored — a direct enabler of the 7.8-hour dwell time.

CONTRIBUTING FACTORS:

- No email sandboxing or advanced attachment analysis in the email gateway.
- Endpoint Detection & Response (EDR) not deployed; behavioral anomalies (e.g., process injection, unusual parent-child process trees) went undetected.
- No network segmentation between user workstations and the file server containing PHI.

- Lack of least-privilege enforcement allowed harvested credentials to authenticate to FS01.

5. Containment & Eradication

5.1 Immediate Containment Actions

- Compromised workstation isolated from network at T+9:50 (switch port disabled via network access control).
- C2 IP address (185.220.xx.xx) and associated domain (*.duckdns.org) blocked at perimeter firewall and DNS sinkhole.
- All active sessions for compromised accounts terminated; passwords force-reset for 3 affected domain accounts.
- File server FS01 taken offline pending forensic review; access via VPN revoked for affected users.

5.2 Eradication Steps

- Malicious binary (svchost32.exe) and staging directory deleted from all affected hosts.
- Persistence mechanisms removed: Registry Run key deleted, malicious scheduled task removed.
- Compromised workstation wiped and rebuilt from verified clean image; joined to domain with fresh credentials.
- FS01 restored from last known-good backup; file integrity verified via SHA-256 hash comparison.
- Wazuh detection rules updated: new rules added for outbound TCP on ports 4444, 1234, 8888, and other non-standard ports with anomaly scoring.

5.3 Verification

- 48-hour enhanced monitoring period post-eradication: no recurrence of C2 beaconing observed.
- Vulnerability scan and EDR pilot deployed on rebuilt host — clean baseline confirmed.
- Incident formally closed; lessons-learned session scheduled with SOC and IT management.

6. Incident Metrics

The following metrics measure the organization's detection and response performance against industry-standard targets. All values require significant improvement.

Metric	Actual Value	Target	Assessment
Mean Time to Detect (MTTD)	7 hours	< 1 hour	CRITICAL — 7x above target. Manual detection only.
Mean Time to Respond (MTTR)	2 hours	< 30 min	NEEDS IMPROVEMENT — 4x above target. No automated playbook.

Dwell Time	7.8 hours	< 1 hour	CRITICAL GAP — Extended dwell enabled full exfiltration.
False Positive Rate	N/A*	< 5%	* Insufficient alert volume during incident to calculate meaningful rate.
Alerts Generated During Dwell	0	> 1	CRITICAL — Zero automated alerts during entire 7.8-hour attack window.
Containment Completeness	100%	100%	TARGET MET — All affected systems contained and rebuilt.

7. Identified Gaps & Recommendations

Four critical security gaps were identified. The following table maps each gap to a concrete, prioritized recommendation with expected outcome.

Gap Identified	Concrete Recommendation	Priority	Expected Outcome
No detection rule for port 4444 C2 traffic — attacker operated undetected for 7.8 hours.	Add Wazuh rules for non-standard outbound TCP ports (4444, 1234, 8888, etc.) with alert severity HIGH. Implement anomaly-based detection for new C2 channels. Review all SIEM rules quarterly.	P1	Reduce MTTD to < 30 minutes for C2 activity.
No email sandboxing — phishing document executed without inspection.	Deploy email sandbox (Proofpoint TAP, Microsoft Defender for Office 365, or equivalent). Enable detonation of all Office macro-enabled attachments. Block .docm/.xlsm by default; require business justification for exceptions.	P1	Block initial access vector entirely for macro-based phishing.
No scheduled detection engineering process — SIEM rules 6+ months stale.	Establish a monthly Detection Engineering Review process: assign ownership to a Detection Engineer role, use MITRE ATT&CK coverage heatmaps to identify gaps, track detection KPIs on a dashboard (Kibana or Grafana). Formalize in SOC runbook.	P2	Prevent recurrence of stale detection coverage; mature SOC to Level 3.
No endpoint behavioral monitoring — process injection and credential dumping undetected.	Deploy EDR solution (CrowdStrike Falcon, SentinelOne, or Microsoft Defender for Endpoint) with process injection detection, LSASS protection, and behavioral AI enabled. Enroll all endpoints within 30 days. Configure automated isolation for HIGH confidence detections.	P1	Detect and block Mimikatz, process hollowing, and lateral movement in real time.

8. Post-Incident Analysis Summary

A threat actor gained initial access via a phishing email with a macro-enabled attachment, establishing a reverse shell C2 channel on TCP port 4444. Patient data was exfiltrated over a 7.8-hour dwell period due to a complete absence of automated detection. Root cause analysis identified the absence of a formal SOC improvement framework as the systemic driver — resulting in stale SIEM rules, no EDR deployment, and no email sandboxing. Priority recommendations are: deploy EDR with behavioral detection, implement email attachment sandboxing, add SIEM rules for non-standard C2 ports, and establish a monthly detection engineering review process.

9. Executive Briefing — CEO / Board

WHAT HAPPENED

Our organization experienced a targeted cyberattack in which an employee was deceived into opening a malicious email attachment. This gave an attacker remote access to our internal systems. Over the following eight hours, the attacker moved through our network and copied a set of patient health records before the security team detected the activity and shut down the intrusion.

WHAT DATA WAS AT RISK

Protected Health Information (PHI) — including patient records stored on an internal file server — was potentially accessed and copied. The full scope of the affected records is currently being assessed with the assistance of legal counsel and our data privacy team to determine notification obligations under HIPAA and applicable state law.

WHAT HAS BEEN DONE

The security team moved swiftly once the attack was detected. The attacker's access was cut off, affected systems were quarantined and rebuilt, and all known attack channels were blocked. Compromised staff credentials were reset and access was re-verified. No evidence of ongoing attacker presence has been found in the 48 hours since containment. An independent forensic review is underway to confirm the full extent of the breach.

WHAT THE COMPANY NEEDS TO INVEST IN NEXT

This incident exposed three critical gaps that require immediate investment:

1. **Endpoint Security Software (EDR):** Tools that monitor all computers in real time and automatically stop suspicious behavior — similar to an immune system for our devices. Estimated cost: \$X per endpoint/year.
2. **Email Security:** A system that automatically inspects every email attachment in a safe environment before it reaches an employee's inbox, blocking threats like the one used in this attack. Estimated cost: \$X per user/year.
3. **SOC Maturity & Ongoing Alerting:** Dedicated resources and a formal review cycle to keep our security monitoring current. Without regular updates, our alert systems fall behind modern attack techniques — exactly what occurred here.

These investments are not optional enhancements — they are foundational requirements for protecting patient data, maintaining regulatory compliance, and preserving organizational trust. The security team will present a detailed budget proposal and implementation roadmap at the next board meeting.

10. Reference Sources & Evidence

The following resources were used as practice evidence sources and for threat intelligence during this simulated exercise:

Disk & Memory Evidence

- CyberDefenders "Insider" Challenge — <https://cyberdefenders.org/blueteam-ctf-challenges/insider>
- CyberDefenders "HireMe" Challenge — <https://cyberdefenders.org/blueteam-ctf-challenges/hireme>
- Digital Corpora Disk Images — <https://digitalcorpora.org/corpora/disk-images>
- CyberDefenders "MemLabs" — <https://cyberdefenders.org/blueteam-ctf-challenges/memlabs>
- Volatility Foundation Memory Samples — <https://github.com/volatilityfoundation/volatility/wiki/Memory-Samples>

Network & Malware Evidence

- Malware Traffic Analysis PCAP Exercises — <https://www.malware-traffic-analysis.net/training-exercises.html>
- CyberDefenders "PacketMaze" — <https://cyberdefenders.org/blueteam-ctf-challenges/packetmaze>
- MalwareBazaar — <https://bazaar.abuse.ch/browse>
- TheZoo (Isolated VM only) — <https://github.com/ytisf/theZoo>

Full Simulation Scenarios

- Blue Team Labs Online — <https://blueteamlabs.online/home/challenges>
- CyberDefenders Full Challenges — <https://cyberdefenders.org/blueteam-ctf-challenges>

Threat Intelligence

- AlienVault OTX — <https://otx.alienvault.com>
 - MITRE ATT&CK Framework — <https://attack.mitre.org>
 - VirusTotal — <https://www.virustotal.com>
-